

Curso de Ciberseguridad 2026



Profesores: Fanny Montoya
Germán Parisi
Matias Galanti

Alumno: Herrera Alex Javier Bruno

Año:2026

Objetivo 2 Laboratorios: Observaciones:

Gran rifa 2019:

Primero comenzamos leyendo bien los que nos pide que tenemos que hacer la consigna e interpretar bien la consigna para tener un mejor trabajo y preciso.

Comenzamos entrando en la sesión de la gran rifa y buscamos el nombre de la persona que tenemos que trabajar, vemos que tiene un botón de editar, pero solo es para el nombre y no es lo que necesitamos, ya que estamos a nivel de cliente no como servidor. Por ello abrimos la terminal del navegador (Presionado F12), lo cual nos abre una terminal donde podremos trabajar a nivel de servidor.

Entramos en la parte de Network donde trabajamos con las peticiones y respuestas del servicio Cliente-Servidor, donde nos saldrá todas las peticiones que vamos a necesitar, primero en la parte de filtros seleccionamos XHR porque son las peticiones puras que van al backend.

Primero creamos una petición apretando el botón editar en la persona que necesitamos así nos saldrá una petición al nombre de api/numeros/4/editar/, le damos click derecho y seleccionamos la opción editar y reenviar, buscamos por la parte derecha al usuario Jhon Backus en api/números/ y observamos los datos que tiene, ahora en la parte de los datos arriba a la derecha podemos poner los datos sin procesar para que aparezca en su forma de código jason para poder copiarlo solo la parte de John Backus y pegarlo en el body de la parte izquierda ya que usaremos la configuración PUT para que cambie todo ese parámetro sin errores, ya que si usamos el PATCH necesitamos solamente copiar la parte entre los corchetes si esta pago o no, ya que es un cambio parcial y no completo.

En este caso particular tuvimos que usar POST porque no funciono con ninguno de los otros dos, pero es lo mismo y funciona.

Ventas:

Primero comenzamos leyendo bien los que nos pide que tenemos que hacer la consigna e interpretar bien la consigna para tener un mejor trabajo y preciso.

Al comenzar vemos que la pagina esta como si no funcionara y eso nos confunde, pero al comenzar el testing con f12 podemos ver unos errores **404**, al leer de nuevo el enunciado nos dirigimos a la ruta de la página y le agregamos **/ventas** y podemos ver que nos sale ahora un error **400** y con esto podemos darnos cuentas como seguir ya que al ser un parámetro get podemos poner parámetros en la URL con el cual podemos buscar o recuperar información desde el servidor.

Con lo anterior más claro podemos buscar las siguientes ventas atreves del id de cada venta, seria así **ventas/?id=1 ; ventas/?id=2 ; ... ; ventas/?id=n**.

Al probar con **ventas/?id=1** podemos ver que nos da un error 403 que nos dice que es una venta realizada ya que al ser un **forbbiden** no nos da autorización

de ver esa venta, con esto podemos saber que los errores **404** no son ventas y los errores **403** son las ventas realizadas por el usuario.

Como no sabemos cuántas ventas fueron realizadas ahora trabajaremos con nuestra nueva herramienta llamada **Burp Suite** que nos ayudara con este problema, lo tenemos que instalar en nuestra pc, así como la extensión **FoxyProxy** para que se conecte a nuestro navegador el **Burp Suite** y no tener que usar su navegador y es más cómodo para cada uno.

En **Burp Suite** entramos en la pestaña de proxy y prendemos el **FoxyProxy**, recargamos la pagina de ventas, vemos que no nos sale los endpoint y es porque se mandaron al **Burp Suite**, desde allí buscamos la URL de ventas/?id=1 en el cual le damos segundo clic y seleccionamos **send intruder** donde en la cabecera nos vamos a la pestaña de **Intruder** nos sale todo los datos de esa pestaña, ahora seleccionamos la parte de **?id=1** en la parte de arriba nos sale una opción de **add\$** la seleccionamos y nos lo marca como una variable en la parte de **\$?id=1\$** en lo cual nos abre un apartado en la derecha **Playloads** en la cual podemos modificar esa variable para lo que necesitemos realizar.

En **Playloads type** seleccionamos number en cual abajo nos dice cuántas peticiones necesitamos realizar comenzamos, comenzamos desde 0 hasta 2000 para saber cuántas ventas realizo el usuario, en la parte superior del cuerpo de la URL nos dice **start attack** le damos clic y nos abre una nueva ventana donde se realiza las peticiones que pedimos, para buscar cuantas ventas realizo el usuario en lo cual vemos que nos manda en el **estatus code** el número **404** y **403** y ordenamos las peticiones y seleccionamos desde la 1 porque la 0 no cuenta porque es la que lanzamos para comenzar las peticiones y arrastramos hasta llegar a la última petición, pero parece que hay más peticiones **403** ya que llegamos la petición 2000 y sigue apareciendo, lo cual aumentamos el rango de las peticiones para el siguiente ataque en lo cual usamos de 1-3000 y esperamos a que se realicen las peticiones, lo cual ordenamos las peticiones y seleccionamos todas hasta llegar a la última y vemos que termina en 2593 y no avanza más, con lo que podemos deducir que no hay más ventas del usuario.

Entonces el usuario tiene **1641** ventas realizadas con lo cual nos dirigimos a nuestro navegador y buscamos una web que nos permita convertir ese número en **MDS** con lo cual nos entregara el código para terminar el laboratorio.

Turnero:

Primero comenzamos leyendo bien los que nos pide que tenemos que hacer la consigna e interpretar bien la consigna para tener un mejor trabajo y preciso.

Al comenzar ingresamos al turnero con los datos que nos dan, al entrar vemos que no tenemos los nombres de los usuarios que sacaron el turno, así que intentamos borrar un turno para ver que endpoint nos tira, nos tira un get y un delete que nos muestra que el turno fue retirado, con eso podemos ver en la cabecera de los endpoint que nos manda un numero al eliminar los turno **/api/1/appointments/**, al deducir esto tratamos de eliminar otro turno,

/api/4/appointments/ podemos ver que cambia los números y podemos deducir que serían los usuarios eliminados con esto podemos buscar las cookies en la sección de **Request Header** donde podemos verificar que los números son los usuarios y con eso probamos cambiando el numero para acceder a los recursos de otros usuarios.

Seleccionamos un **/api/1/appointments/** le damos segundo click con el cual elegimos la opción de editar y enviar, en la sección del **get** al ser el **/api/1/appointments/** nos devuelve los datos del usuario que somos nosotros, ahora probamos con **/api/2/appointments/** podemos ver que no nos devuelve nada en si {} vacios con el cual podemos deducir que ese cliente no existe o no tiene turno, debemos probar así hasta encontrar el usuario **"xdalvik"**.

Siguiendo de esta manera después de un tiempo pudimos encontrar al usuario en el **/api/101/appointments** que nos devuelve sus datos y podemos ver el id que serían los turnos que saco, con esos datos nos vamos al primer **DELETE** que realizamos y le damos segundo click a editar y reenviar con el cual **/api/appointments/numero** en la barra escribimos los turnos que deseamos borrar **(10,11,12,13)** que son los turnos que saco este usuario y con esto refrescamos la página y nos dará el código del laboratorio resuelto.

Presupuesto:

Primero comenzamos leyendo bien los que nos pide que tenemos que hacer la consigna e interpretar bien la consigna para tener un mejor trabajo y preciso.

Entramos a la página de presupuesto y vemos que es un trabajo de calculo que debemos realizar para que los valores estén en los valores que nos piden en ese caso abrimos **F12** y buscamos en los endpoint cuál es el que se encarga de mostrar los títulos de los montos que es la ruta **/api/gastos/** vemos el **json** buscamos las variables, después ponemos a revisar una de las variables para ver como es la ruta para editar tales variables a continuación **/api/gastos/id/editar/**, vemos que esa ruta debemos usar para cambiar el valor de monto de las variables siguiente.

En los gastos esenciales necesitamos igualarlo a 16375 y tenemos por el momento un promedio de 15625, restamos ambos promedios de los gastos esenciales, nos dará un total de 750 y eso lo multiplicamos por la cantidad de títulos esenciales que sería 4 y nos da un total de 3000 lo cual debemos aumentar a uno de los presupuestos y el mejor sería uno intermedio a los datos que es el de la luz o alquiler local. Ahora en el endpoint **/api/gastos/** le damos segundo click y en editar y reenviar. En la ruta ponemos **/api/gastos/3/editar/** es el numero id de la luz así podemos realizar el cambio en ella, ahora seleccionamos **PATCH** para realizar un cambio parcial en el monto y con ello en el cuerpo escribimos **{"monto": "5000"}**, vemos que no funciona intentamos con **POST** ya que nos pasó lo mismo con el ejercicio de la rifa2019 y probamos vemos que nos funciona.

En gastos varios restamos el promedio con los que nos pide que tiene que ser el gasto y nos da 333.33 y lo multiplicamos por 6 y nos da 2000 que es la cantidad que tenemos que aumentar a 1 variable intermedia de esos gastos para ello elegimos **licencias de software** que tiene un monto de 2000 y le aumentamos la cantidad requerida que tiene que ser de 3666.65 lo cual buscamos su id que es 12 y modificamos la ruta **/api/gastos/12/editar/** y modificamos el dato en el cuerpo con **{“monto”:”4000”}** una vez modificado nos aceptó con el método **POST**.

En el monto promedio total debemos restar el valor actualmente con el que nos pide y nos da 730.77 lo cual lo multiplicaremos por todos los títulos (13) y nos da 9500 lo cual debemos restar a unos de los títulos que no modificamos hasta ahora, nos queda el Agua que le podemos restar 500 para que tenga el monto mínimo y restamos 4500 a los impuesto y transporte con lo cual nos dará un promedio total de 8000 que es lo que buscamos.

Para terminar, revisamos cada uno de los títulos y así nos entregara el código para dar como terminado el laboratorio.